Maintainer Prioritization in npm Supply Chains: Objectives, Representation Sensitivity, and Metadata Limits

Shahriar Hasan*
First author and corresponding author
Department of ECE
Hajee Mohammad Danesh Science and Technology University
Basherhat, HSTU, Dinajpur – 5200, Bangladesh
Email: hasanshahriar32@gmail.com
ORCID: https://orcid.org/0009-0006-4448-9209

Ashikul Islam
Department of CSE
Hajee Mohammad Danesh Science and Technology University
Basherhat, HSTU, Dinajpur – 5200, Bangladesh
Email: ashikulislamcf2000@gmail.com
ORCID: https://orcid.org/0009-0009-6384-5223

*Correspondence: Shahriar Hasan
hasanshahriar32@gmail.com
Department of ECE, Hajee Mohammad Danesh Science and Technology University,
Basherhat, HSTU, Dinajpur – 5200, Bangladesh

Statements and Declarations

Funding

This research received no external funding.

Competing Interests

Both authors declare that they have no financial or non-financial competing interests relevant to this work.

Data Availability

The retained input archive, new observation records, derived analysis tables, protocols and checksums are available in the versioned research prerelease `research-validation-2026-10-28`: `https://github.com/hasanshahriar32/npm-supply-chain-research/releases/tag/research-validation-2026-10-28`. Download the attached companion and its checksum-verified original input linked at a fixed repository commit. Independent human audit annotations remain pending. Third-party workflow, manifest and lockfile bodies are referenced by pinned source URLs and hashes; the release contains derived audit observations.

Code Availability

The same versioned artifact provides collection and analysis scripts, exact benchmark inputs, numerical consistency checks and figure-generation code. Its README describes checksum verification and offline numerical reproduction after downloading the original input. The numerical path uses captured observations and does not repeat live API requests. Repeating acquisition may return different metadata. Raw third-party source inspection is separate from the released derived-data reproduction; it does not establish completed human review or workflow execution.

Ethics and Consent

The study analyzes public software-ecosystem metadata and does not involve recruited human participants, interventions on individuals, or execution of package payloads. No participant consent was collected. Usernames are used as observed graph identifiers, without inferring misconduct or present-day account security. The prospective observations contain no measured incident outcomes at the time of this manuscript.

Publication Status

Neither the conference-length draft nor the journal manuscript has been published, accepted, or is under review elsewhere. This manuscript is not an extension of a previously published conference paper.

Acknowledgments

The authors thank npm package maintainers and the open-source community for the studied public artifacts, and deps.dev and GitHub for data interfaces.